

AUDIT ET SÉCURISATION D'ACTIVE DIRECTORY AVEC PINGCASTLE

Méthodologie d'Audit & Remédiation

Niveau : BTS SIO SISR

Épreuve cible : E6 - Administration Systèmes et Réseaux

Outil principal : PingCastle v3.x

Prérequis : Une machine virtuelle Windows Server (AD DS) et un client Windows 10/11 fonctionnel ajouté au domaine.



SOMMAIRE DU COURS

- I. INTRODUCTION : COMPRENDRE L'AUDIT AD**
- II. PLONGÉE TECHNIQUE : COMMENT FONCTIONNE PINGCASTLE ?**
- III. ÉTAPE 1 : PRÉPARATION DU LAB ET SCAN DE RÉFÉRENCE (BASELINE)**
- IV. MISSION 1 : L'HYGIÈNE DES COMPTES (STALE OBJECTS)**
- V. MISSION 2 : LA CHASSE AUX PRIVILÈGES (PRIVILEGED ACCOUNTS)**
- VI. MISSION 3 : LE DURCISSEMENT DES SERVICES (ANOMALIES)**
- VII. BILAN ET MÉTHODOLOGIE D'EXAMEN (E6)**

I. INTRODUCTION : COMPRENDRE L'AUDIT AD

En tant que technicien SISR, vous apprendrez que **80% des cyberattaques majeures** (comme les ransomwares) aboutissent parce que l'Active Directory est mal configuré. L'AD est le "coffre-fort" de l'entreprise. S'il est compromis, c'est tout le système d'information qui tombe.

Ce cours a pour but de vous apprendre non pas à installer un AD, mais à l'**auditer** et à le **durcir** de manière méthodique.

II. PLONGÉE TECHNIQUE : COMMENT FONCTIONNE PINGCASTLE ?

Développé par un expert français (Vincent Le Toux), PingCastle est devenu le standard de l'industrie pour évaluer rapidement la maturité d'un environnement Microsoft. Voici ce que vous devez comprendre sur son fonctionnement interne :

1. L'architecture de l'outil

PingCastle est écrit en C#. C'est un exécutable **portable**, c'est-à-dire qu'il ne nécessite aucune installation. Cela permet de l'exécuter depuis une simple clé USB ou un partage réseau. Il est "Agentless" (sans agent à déployer sur les serveurs).

2. Comment interroge-t-il l'Active Directory ?

PingCastle n'exploite **aucune faille de sécurité**. Il utilise le comportement normal de Windows. Il interroge la base de données de l'AD via le protocole **LDAP** (Lightweight Directory Access Protocol) et collecte des informations via des requêtes **SMB** et **RPC**.

Fait critique : Un simple compte utilisateur du domaine (sans aucun droit d'administration) a, par défaut, le droit de lire la majorité de la structure de l'AD. PingCastle utilise ce droit en lecture seule pour construire son rapport !

3. Le modèle d'évaluation (Scoring)

PingCastle analyse l'AD sous 4 grands axes d'évaluation (appelés "Indicateurs") :

- **Stale Objects (Comptes inactifs)** : Les comptes qui n'ont pas été utilisés depuis des mois ou sans mot de passe.
- **Privileged Accounts (Comptes privilégiés)** : L'analyse du groupe "Admins du Domaine" et des délégations.
- **Trusts (Relations d'approbation)** : Les liens entre différents domaines (hors périmètre de ce TP).
- **Anomalies** : Les mauvaises configurations de serveurs (SMBv1 actif, Spouleur d'impression, etc.).

III. ÉTAPE 1 : PRÉPARATION ET SCAN DE RÉFÉRENCE

Attention : Vérifiez que vos machines virtuelles (Serveur et Client) sont connectées au même réseau virtuel privé (**NAT** ou **Host-Only**). Désactivez temporairement l'antivirus Windows Defender sur votre client de test, car il bloque parfois l'exécution d'outils d'audit.

1. Polluer l'Active Directory (Pour le TP)

Un AD tout neuf est trop parfait. Pour que l'audit soit intéressant, exécutez ces actions sur votre serveur :

1. Créez 3 utilisateurs (ex: *j.dupont*, *j.malek*, *j.adam*).
2. Cochez la case "**Le mot de passe n'expire jamais**" pour ces 3 comptes.
3. Ajoutez le compte *j.adam* dans le groupe "**Admins du domaine**".

2. Lancer la Baseline (Le scan initial)

Une "Baseline" est votre état de référence. C'est le score avant votre intervention.

1. Téléchargez PingCastle depuis le site officiel et extrayez-le sur votre VM Client.
2. Double-cliquez sur `PingCastle.exe` (En tant qu'utilisateur simple, pas d'Admin requis).

 Active_Directory_Security_Self_Assessment_v1.4	19/04/2026 16:13	Microsoft Edge PDF Document	2 739 Ko
 appsettings.console.json	19/04/2026 16:13	Fichier JSON	1 Ko
 license.rtf	19/04/2026 16:13	Fichier RTF	13 Ko
 PingCastleAutoUpdater	19/04/2026 16:13	Application	156 808 Ko
 PingCastle	19/04/2026 16:13	Application	238 031 Ko

Voici une explication des 5 fichiers présents dans le dossier téléchargé :

- `Active_Directory_Security_Self_Assessment_v1.4.pdf` : C'est la véritable "Bible" de l'outil. Ce n'est pas un simple manuel d'utilisation de clics, mais un document méthodologique de haut niveau. Il explique la théorie de la sécurité Active Directory, les modèles de maturité, et justifie techniquement pourquoi telle ou telle configuration est considérée comme un risque.
- `appsettings.console.json` : C'est le fichier de configuration technique de l'application console (au format JSON). Il contient des paramètres avancés "sous le capot", comme la gestion des proxies ou le niveau de détail des journaux (logs) de l'outil.
- `license.rtf` : Le document juridique contenant les conditions d'utilisation. PingCastle a une licence spécifique. Il est gratuit pour un usage personnel ou pour l'équipe informatique interne d'une entreprise qui audite son propre réseau. Mais si une entreprise de conseil (ESN) l'utilise pour facturer un audit à un client, elle doit acquérir une licence professionnelle.

- **PingCastleAutoUpdater.exe** : Comme son nom l'indique, c'est l'utilitaire de mise à jour. Le monde de la cybersécurité évoluant tous les jours, de nouvelles vulnérabilités Active Directory sont régulièrement découvertes. En entreprise, l'auditeur lance souvent cet utilitaire avant sa mission pour s'assurer qu'il dispose des toutes dernières règles de détection.
- **PingCastle.exe**: C'est le moteur principal, le "cerveau" de l'outil. C'est ce fichier que vos étudiants vont double-cliquer pour lancer l'audit. Remarquez sa taille importante (238 Mo) : c'est parce que PingCastle est conçu pour être totalement autonome (standalone). Il embarque toutes les bibliothèques logicielles (comme le framework .NET) dont il a besoin. Ainsi, l'auditeur peut l'exécuter depuis une simple clé USB sur n'importe quel serveur ou poste de l'entreprise, sans rien avoir à "installer" au préalable (ce qui est une règle d'or en audit : on ne modifie pas l'environnement du client).

3. Ensuite tapez **1 (Healthcheck-Score)** et appuyez sur Entrée.

```

C:\Users\j.dupont\Downloads >
***** Netwrix PingCastle (Version 3.5.0.44)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-08-31.
***** #####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html

What do you want to do?
=====
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-entraid -Score the risk of Entra ID
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
=====
This is the main functionality of PingCastle. In a matter of minutes, it produces a report which will give you an overview of your Active Directory security. This report can be generated on other domains by using the existing trust links.

```

4. Ensuite, tapez **2 (No)** puis Entrée pour auditer votre domaine actuel.

5. Ouvrez le « gros » fichier HTML généré. Le second fichier HTML contient les données brutes extraites de l'AD afin d'être exploitable dans d'autres conditions. **Notez votre score global de risque (sur 100).**

	ad_hc_sisr.local	19/04/2026 17:27	Microsoft Edge HTML Document	1 579 Ko
	ad_hc_sisr.local	19/04/2026 17:27	Microsoft Edge HTML Document	48 Ko
	Active_Directory_Security_Self_Assessment_v1.4	19/04/2026 16:13	Microsoft Edge PDF Document	2 739 Ko
	appsettings.console.json	19/04/2026 16:13	Fichier JSON	1 Ko
	license.rtf	19/04/2026 16:13	Fichier RTF	13 Ko
	PingCastleAutoUpdater	19/04/2026 16:13	Application	156 808 Ko
	PingCastle	19/04/2026 16:13	Application	238 031 Ko

Healthcheck analysis

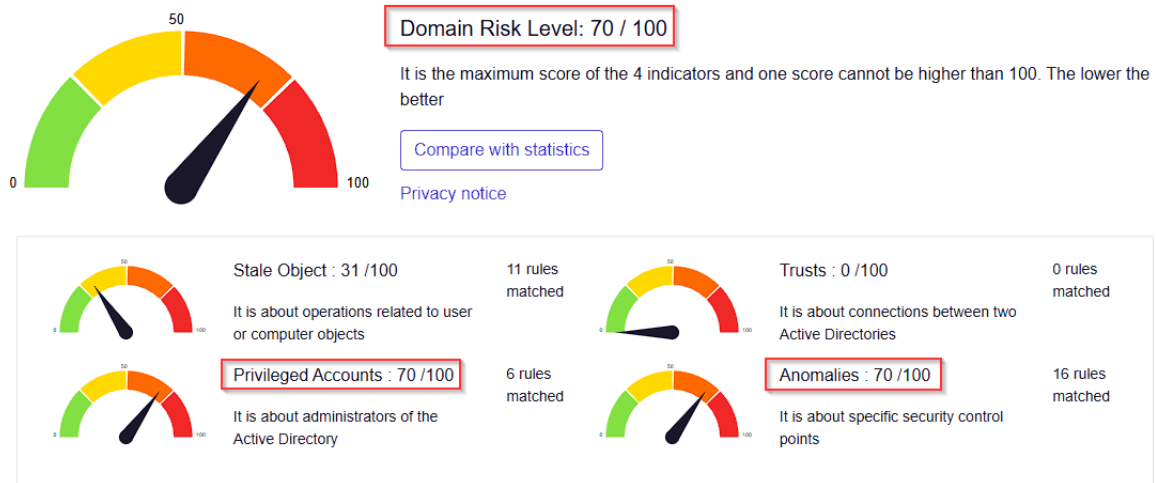
Date: 2026-04-19 - Engine version: 3.5.0.44

This report has been generated with the Basic Edition of PingCastle .
Being part of a commercial package is forbidden (selling the information contained in the report).
If you are an auditor, you MUST purchase an Auditor license to share the development effort.

Active Directory Indicators

This section focuses on the core security indicators.
Locate the sub-process determining the score and fix some rules in that area to get a score improvement.

Indicators



Analysons maintenant les données de notre fichier :

Tout d'abord l'indicateur principal qui, dans notre cas, nous donne un score de **70/100**. Ce score correspond au **score le plus élevé** relevé dans l'analyse, c'est-à-dire pour les piliers « Privileged Accounts » et « Anomalies ». Ce n'est donc pas la moyenne des 4 piliers ! En effet, plus ce score est élevé, plus le niveau de risque de compromission est important ! Nous constatons qu'il y a un code de 4 couleurs (vert, jaune, orange et rouge) correspondant au 4 niveaux de risque, du moins critique (vert) au plus critique (rouge).

Décryptons chaque pilier :

Stale Objects (31 / 100) - Zone verte/orange :

L'hygiène de base. Ce sont les "objets obsolètes" (11 règles déclenchées). Cela signifie qu'il y a des ordinateurs ou des utilisateurs qui ne se sont pas connectés depuis longtemps, ou des comptes dont le mot de passe n'expire jamais. Ce n'est pas le plus critique ici, mais ça demande un peu de ménage.

Privileged Accounts (70 / 100) - Zone rouge :

C'est l'un de nos gros problèmes. Bien qu'il n'y ait que 6 règles déclenchées, leur "poids" est énorme. Cela indique qu'il y a des problèmes graves avec les comptes d'administration (ex:

trop de membres dans le groupe Admins du domaine, ou des comptes de service qui ont trop de droits).

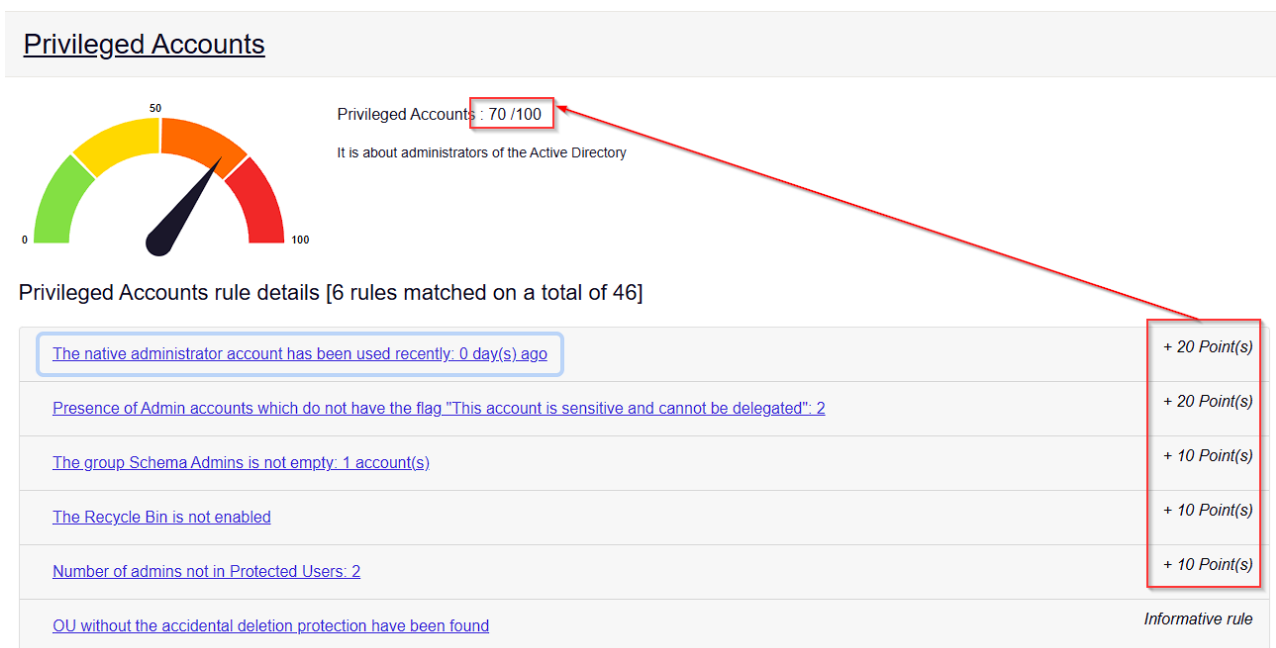
Trusts (0 / 100) - Zone verte :

Score parfait. Cela évalue les relations de confiance (Trusts) avec d'autres forêts ou domaines Active Directory. Dans notre maquette, notre domaine est isolé, donc il n'y a aucun risque de ce côté-là.

Anomalies (70 / 100) - Zone rouge :

C'est notre deuxième gros problème (16 règles déclenchées). Cela regroupe toutes les mauvaises configurations de base du serveur et les protocoles obsolètes (ex: le Spouleur d'impression actif sur le contrôleur de domaine, l'absence de signature SMB, l'utilisation de SMBv1, etc.).

Détail des scores :



Privileged Accounts



Privileged Accounts : 70 /100
It is about administrators of the Active Directory

Privileged Accounts rule details [6 rules matched on a total of 46]

The native administrator account has been used recently: 0 day(s) ago + 20 Point(s)

Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 2 + 20 Point(s)

At least one administrator account can be delegated

Rule ID:
P-Delegated

Description:
The purpose is to ensure that all Administrator Accounts have the configuration flag "this account is sensitive and cannot be delegated" (or are members of the built-in group "Protected Users" when your domain functional level is at least Windows Server 2012 R2).

Technical explanation:
Without the flag "This account is sensitive and cannot be delegated" any account can be impersonated by some service account. It is a best practice to enforce this flag on administrators accounts.

Advised solution:
To correct the situation, you should make sure that all your Administrator Accounts have the check-box "This account is sensitive and cannot be delegated" active or add your Administrator Accounts to the built-in group "Protected Users" if your domain functional level is at least Windows Server 2012 R2 (some functionalities may not work properly afterwards, you should check the [official documentation](#)).
If you want to enable the check-box "This account is sensitive and cannot be delegated" but this is not possible because the box is not present (typically for GMSA accounts), you can add the flag manually by adding the number 1048576 to the attribute useraccountcontrol of the account.
Please note that there is a section below in this report named "Admin Groups" which gives more information.

Points:
20 points if present

Documentation:
[\[US\]STIG V-36435 - Delegation of privileged accounts must be prohibited.](#)
[\[MITRE\]Mitre Att&ck - Mitigation - Active Directory Configuration](#)

Details:
The detail can be found in [Admin Groups](#)

DN	Reason
CN=Administrateur,CN=Users,DC=sisr,DC=local	Not a protected user
CN=jean adam,OU=Utilisateurs,OU=Compta,DC=sisr,DC=local	Not a protected user

Les points pour chaque règle ne sont pas attribués au hasard. PingCastle s'appuie sur une véritable méthodologie d'analyse de risques et sur le framework international **MITRE ATT&CK** (la bible des cyberattaques).

PingCastle ne fait pas une simple addition ($10 + 20 + 30 = 60/100$). Il utilise une courbe **mathématique asymptotique**.

Imaginez un seau percé (la sécurité de l'entreprise). Si vous avez 500 points de pénalités cumulés, votre score ne sera pas de 500/100, il sera plafonné à 100/100 (le maximum). Quand vous êtes dans le rouge vif (ex: 100/100), corriger une petite faille de 10 points ne fera pas bouger le score, car vous avez encore trop de pénalités graves en attente. Le score ne commencera à chuter de manière visible que lorsque vous aurez 'purgé' les failles les plus lourdes. C'est le principe de la **priorisation des risques**.

Prenons l'image ci-dessus, traduite en français, afin de voir le détail de cette règle :

Au moins un compte administrateur peut être délégué.

ID de la règle :
P-Délégué

Description :
L'objectif est de s'assurer que tous les comptes d'administrateur possèdent l'indicateur de configuration « ce compte est sensible et ne peut pas être délégué » (ou sont membres du groupe intégré « Utilisateurs protégés » lorsque le niveau fonctionnel de votre domaine est au moins Windows Server 2012 R2).

Explication technique :
Sans l'indicateur « Ce compte est sensible et ne peut être délégué », n'importe quel compte peut être usurpé par un compte de service. Il est donc fortement recommandé d'activer cet indicateur sur les comptes administrateurs.

Solution conseillée :
Pour corriger ce problème, assurez-vous que la case « Ce compte est sensible et ne peut être délégué » est cochée pour tous vos comptes d'administrateur, ou ajoutez-les au groupe intégré « Utilisateurs protégés » si votre domaine utilise au moins Windows Server 2012 R2 (certaines fonctionnalités peuvent ne plus fonctionner correctement par la suite ; consultez la [documentation officielle](#)).
Si vous souhaitez cocher la case « Ce compte est sensible et ne peut être délégué », mais que cela est impossible car elle est absente (généralement pour les comptes GMSA), vous pouvez ajouter l'indicateur manuellement en ajoutant le nombre 1048576 à l'attribut useraccountcontrol du compte.
Veuillez noter que la section « Groupes d'administrateurs » ci-dessous fournit des informations complémentaires.

Points :
20 points si présent

Documentation :
[\[US\]STIG V-36435 - La délégation de comptes à privilèges doit être interdite.](#)
[\[MITRE\]Mitre Att&ck - Atténuation - Configuration d'Active Directory](#)

Détails :
Vous trouverez plus de détails dans [les groupes d'administration](#).

DN	Raison
CN=Administrateur,CN=Utilisateurs,DC=sisr,DC=local	Utilisateur non protégé
CN=jean adam,OU=Utilisateurs,OU=Compta,DC=sisr,DC=local	Utilisateur non protégé

Pingcastle donne des détails de manière simple et explicite sur chaque section afin de pouvoir agir rapidement et efficacement. Ainsi, nous trouvons une **description** de la règle, une **explication technique**, une **solution conseillée**, le nombre de **points** de criticité, des liens vers de la **documentation** et enfin un **tableau** qui cible précisément les éléments sur lesquels Pingcastle a détecté le problème lié à cette règle afin d'y remédier.

IV. Etape 2 : Mission remédiation

MISSION 1 : L'HYGIENE DES COMPTES (PRIVILEGED ACCOUNTS)

Essayons de réduire le nombre de points (20) de la règle précédente.

1. Analyse des 2 coupables détectés par PingCastle

L'alerte indique que 2 comptes considérés comme "**Administrateurs**" ne sont pas protégés contre le vol de ticket Kerberos (abus de Délégation). En regardant les noms, on constate 2 problèmes totalement différents :

1. **CN=Administrateur** : C'est le vrai compte d'administration système.
2. **CN=jean adam** : C'est un simple utilisateur situé dans l'Unité d'Organisation de la comptabilité.

2. La Remédiation (Un traitement spécifique pour chaque compte)

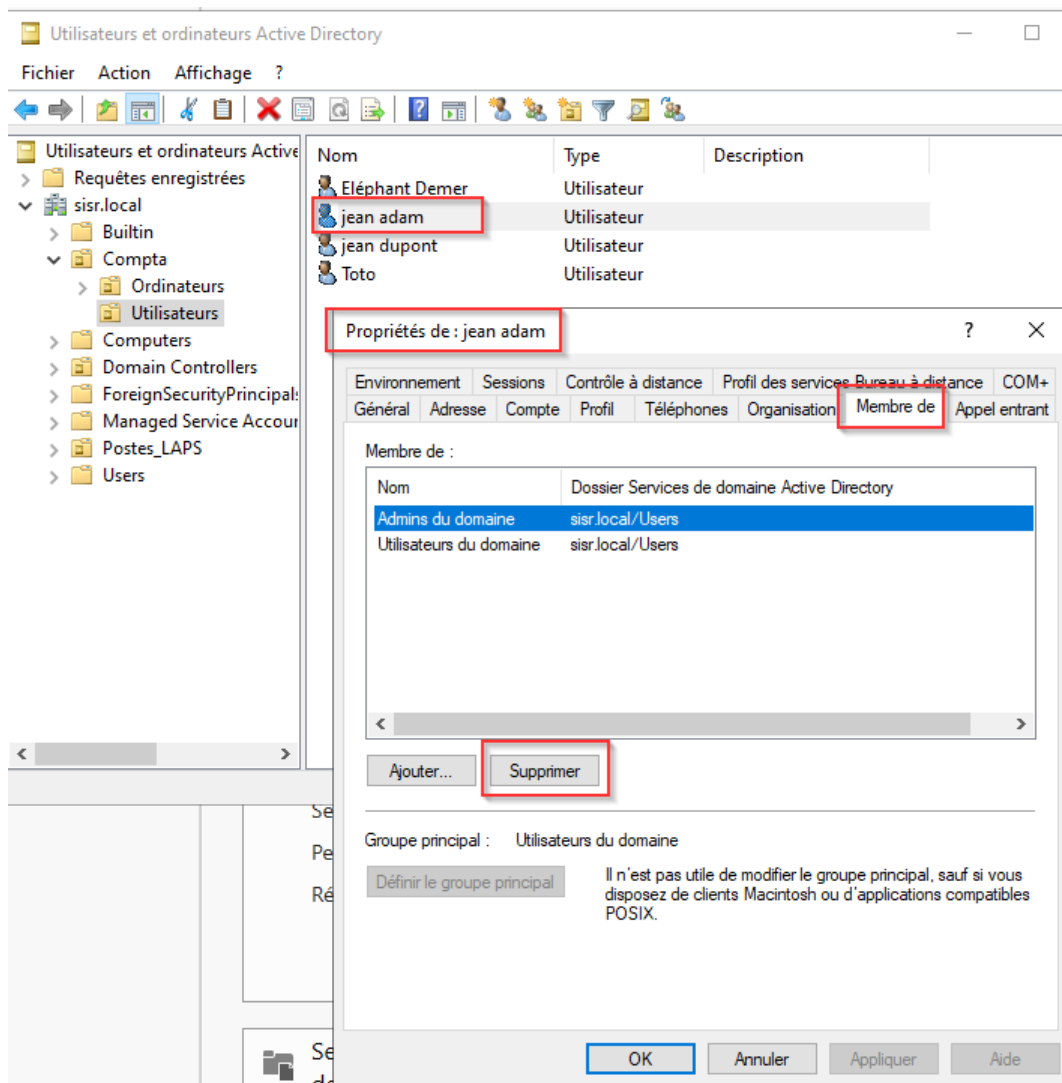
Audit et sécu avec PingCastle

Pour faire disparaître cette alerte de 20 points, vous devez traiter chaque compte selon le principe du **Moindre Privilège**. Allez dans `dsa.msc` (Utilisateurs et ordinateurs Active Directory) et appliquez ces 2 actions :

Action 1 : Le cas "Jean Adam" (L'erreur humaine à corriger)

Un membre du service Comptabilité n'a absolument rien à faire dans une alerte concernant les administrateurs du réseau. C'est certainement une erreur de droits.

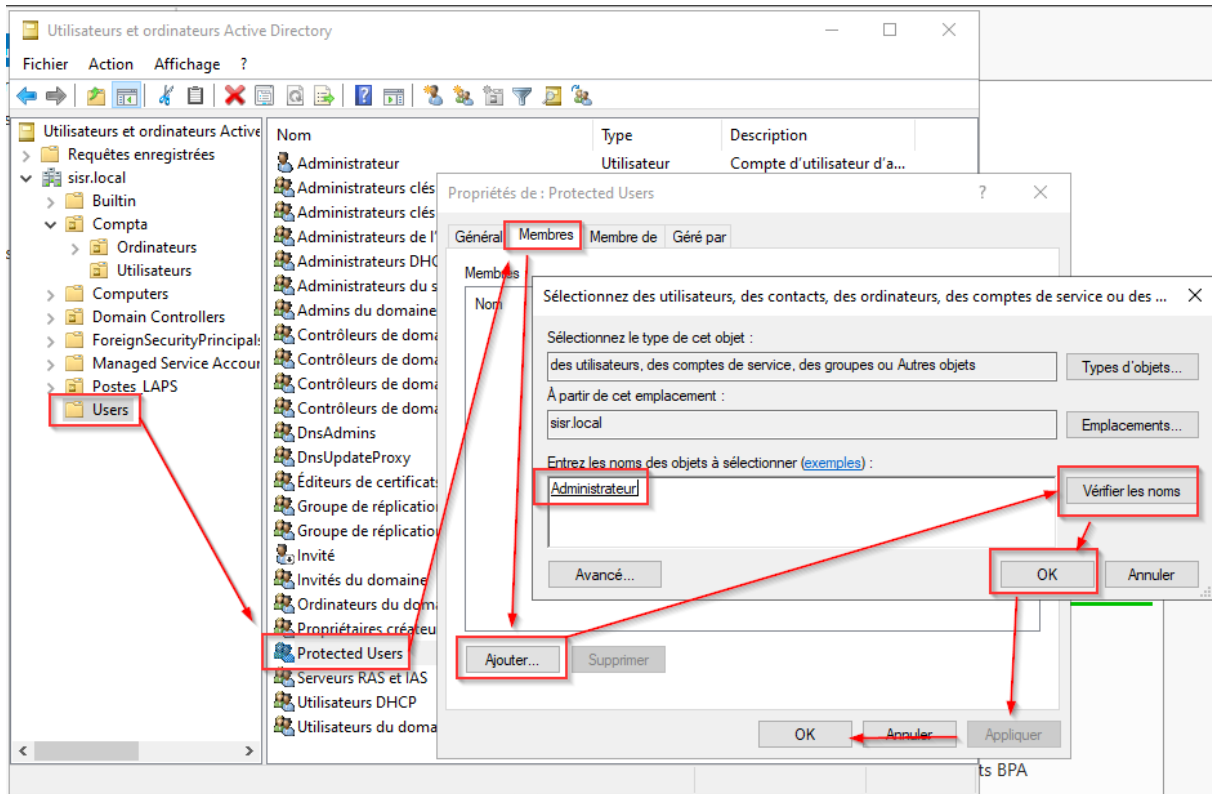
La solution : Ouvrez les **propriétés** du compte `jean adam` > onglet **Membre de** > Retirez-le immédiatement du groupe *Admins du domaine* (ou de tout autre groupe d'administration dans lequel il a été placé par erreur).



Action 2 : Le cas "Administrateur" (La protection technique à activer)

Ce compte est légitime, il faut donc le protéger techniquement contre les attaques d'usurpation (Kerberos Unconstrained Delegation).

La solution : Allez dans le conteneur **Users** (Utilisateurs), trouvez le groupe de sécurité natif appelé **Utilisateurs protégés** (ou *Protected Users*), et ajoutez le compte `Administrateur` à l'intérieur de ce groupe.



Note : Re-générez un rapport PingCastle. Vous verrez que le score de cet indicateur a baissé !

Avant :

Privileged Accounts

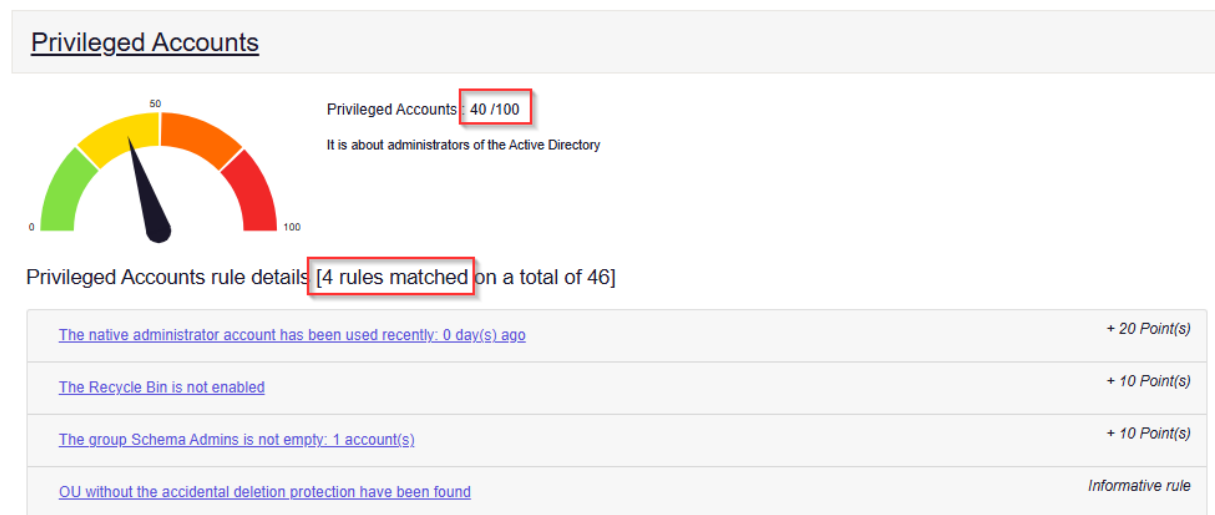


Privileged Accounts : 70 /100
It is about administrators of the Active Directory

Privileged Accounts rule details [6 rules matched on a total of 46]

The native administrator account has been used recently: 0 day(s) ago	+ 20 Point(s)
Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 2	+ 20 Point(s)
The group Schema Admins is not empty: 1 account(s)	+ 10 Point(s)
The Recycle Bin is not enabled	+ 10 Point(s)
Number of admins not in Protected Users: 2	+ 10 Point(s)
OU without the accidental deletion protection have been found	Informative rule

Après :



Cette remédiation nous a permis de **réduire de 30 points** le niveau de criticité. En effet, une autre règle a été supprimé de manière « collatérale » grâce à cette action.

MISSION 2 : SE DEBARASSER DES OBJETS PERIMES (STALE OBJECTS)

Occupons nous maintenant de réduire le score dans le pilier « objets périmés » (stale objects) qui est de 31/100 (**Voir l'image plus bas**).

1. Analyse de l'alerte PingCastle

La Règle (S-OldNtlm) : Le serveur accepte encore que des ordinateurs s'authentifient avec des protocoles des années 90 (NTLMv1 et LM).

Le Score (15 points) : C'est une pénalité moyenne/haute, liée à un risque d'interception réseau.

Le Détail Technique : PingCastle indique : `Windows par défaut sans stratégie de groupe active 3`. Cela signifie que le système est sur le niveau de sécurité 3 par défaut. Or, pour être vraiment sécurisé selon l'ANSSI et la matrice MITRE ATT&CK, il faut **forcer** le niveau 5 via une GPO.

2. L'attaque par Relais NTLM

Le protocole NTLM sert à vérifier les mots de passe sur le réseau. NTLMv1 est l'équivalent d'un cadenas rouillé dont on connaît les faiblesses mathématiques.

"Imaginez qu'un hacker se connecte sur le réseau de l'entreprise. Il utilise un outil (comme Responder) pour écouter le trafic. S'il force le Contrôleur de Domaine à discuter avec lui en utilisant le vieux protocole NTLMv1, le hacker va capturer une "empreinte" (un hash) très faible de la session du serveur.

Grâce à la faiblesse de NTLMv1, le hacker peut casser ce hash avec sa carte graphique en quelques minutes, ou le relayer (l'envoyer à un autre serveur) pour s'authentifier à la place du Contrôleur de Domaine. **Tant que NTLMv1 est toléré sur le réseau, c'est comme laisser la porte ouverte aux attaques de l'Homme du Milieu (Man-in-the-Middle).**"

Objets périmés



Objets périmés: 31/100

Il s'agit d'opérations liées aux objets utilisateur ou ordinateur

Détails de la règle des objets obsolètes [11 règles correspondent sur un total de 56]

Le niveau d'authentification du gestionnaire LAN permet l'utilisation de NTLMv1 ou LM.

+ 15 point(s)

Veillez à interdire les protocoles NTLMv1 et les anciens protocoles LM.

ID de la règle :
S-OldNtlm

Description:
L'objectif est de vérifier si NTLMv1 ou LM peuvent être utilisés par DC.

Explication technique :
NTLMv1 est un protocole ancien, connu pour sa vulnérabilité aux attaques cryptographiques.
Il est généralement utilisé lorsqu'un pirate intercepte le trafic réseau et tente de récupérer les hachages NTLM afin d'usurper l'identité des utilisateurs.

Cette attaque peut être combinée à des attaques par authentification forcée : un pirate force le contrôleur de domaine à se connecter à un hôte contrôlé. Dans ce cas, NTLMv1 peut être spécifié pour permettre au pirate de récupérer le hachage NTLM du contrôleur de domaine, d'usurper son identité et de prendre le contrôle du domaine.
Cette attaque reste possible avec NTLMv2, mais elle est plus complexe.

Windows possède des paramètres de sécurité par défaut concernant LM/NTLM : Windows XP envoie les réponses LM et NTLM ; Windows Server 2003 envoie uniquement la réponse NTLM ; Vista/2008 ; Windows 7/2008 R2 envoie uniquement la réponse NTLMv2.

Cependant, les contrôleurs de domaine ont des paramètres par défaut assouplis pour accepter la connexion des anciens systèmes d'exploitation. Par conséquent, NTLMv1 est accepté par défaut sur les contrôleurs de domaine.
Si aucune stratégie de groupe ne définit le niveau d'authentification du gestionnaire LAN, le contrôleur de domaine utilise la valeur par défaut non sécurisée.

Solution conseillée :
Après avoir vérifié l'utilisation de NTLMv1 (voir les liens ci-dessous), vous devez augmenter le niveau d'authentification du Gestionnaire de réseau local (LAN Manager) sur « Envoyer uniquement les réponses NTLMv2. Refuser LM et NTLM ».
Pour ce faire, modifiez la stratégie « Sécurité réseau : Niveau d'authentification du Gestionnaire de réseau local », accessible via Configuration ordinateur > Paramètres Windows > Paramètres de sécurité > Stratégies locales > Options de sécurité.
La stratégie sera appliquée après le redémarrage de l'ordinateur.

Attention : cette modification peut rendre incompatibles certains logiciels avec NTLMv2, comme les anciennes distributions Linux ou les anciennes versions de Windows antérieures à Vista.
Notez cependant que NTLMv2 peut être activé sur toutes les versions de Windows à partir de Windows 95 et sur les autres systèmes d'exploitation.

Points:
15 points si présent

Documentation:
<https://learn.microsoft.com/en-us/troubleshoot/windows-server/windows-security/audit-domain-controller-ntlmv1>
<https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-restrict-ntlm-ntlm-authentication-in-this-domain>
<https://learn.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-lan-manager-authentication-level>
<https://learn.microsoft.com/en-us/troubleshoot/windows-client/windows-security/enable-ntlm-2-authentication>
[MITRE]1557.001 Man-in-the-Middle : LLMNR/NBT-NS Empoisonnement et Relais SMB
[FR]ANSSI - Recommandations de sécurité relatives à Active Directory - R37 [paragraphe 3.6.2.1]

Détails:
Vous trouverez plus de détails dans les paramètres de sécurité.

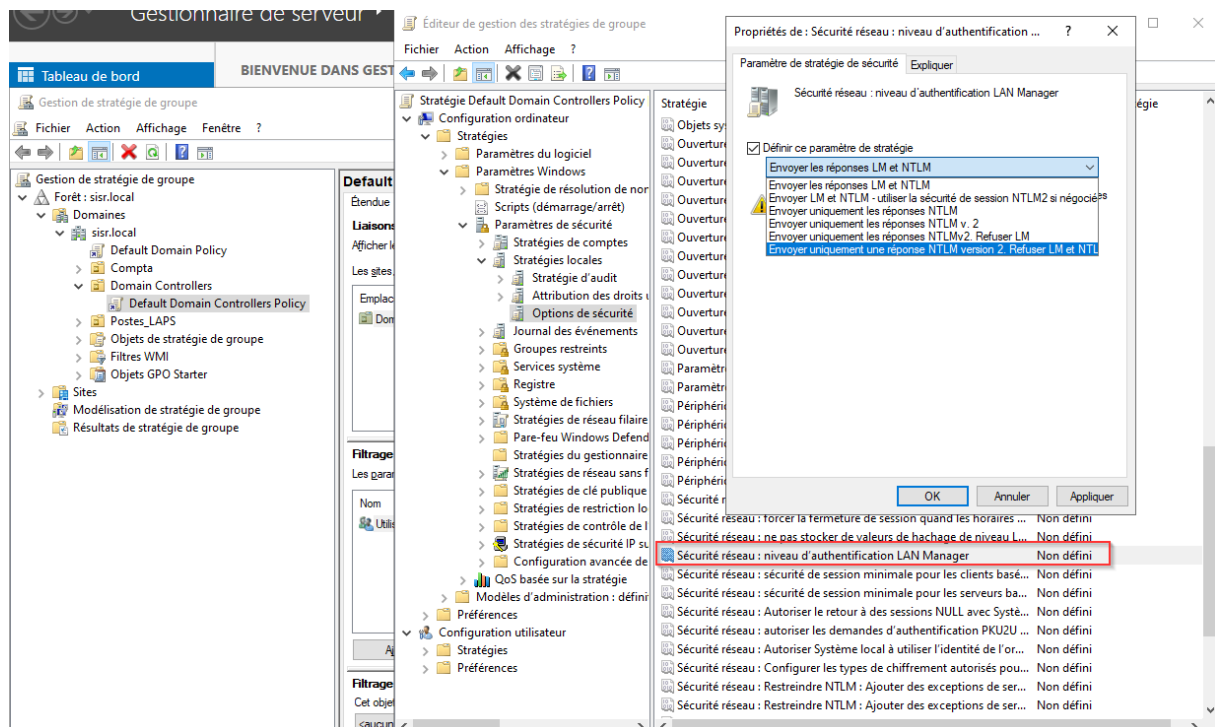
GPO	Valeur
Windows par défaut sans stratégie de groupe active	3

3. La Remédiation (Action requise sur le serveur)

Il faut créer une règle stricte (GPO) pour interdire formellement au Contrôleur de Domaine de "parler" avec ces vieux protocoles.

Procédure de durcissement via GPO :

1. Sur le serveur DC01, ouvrez la **Gestion de stratégie de groupe (gpmc.msc)**.
2. Déroulez : Forêt > Domaines > sirs.local > **Domain Controllers**.
3. Faites un clic droit sur la **Default Domain Controllers Policy** et choisissez Modifier.
4. Naviguez dans ce chemin très précis : Configuration ordinateur > Stratégies > Paramètres Windows > Paramètres de sécurité > Stratégies locales > Options de sécurité.
5. Dans la liste de droite, cherchez la ligne : **Sécurité réseau : niveau d'authentification LAN Manager**.
6. Double-cliquez dessus, cochez "Définir ce paramètre de stratégie" et choisissez dans le menu déroulant l'option la plus stricte : **"Envoyer uniquement les réponses NTLMv2. Refuser LM et NTLM"**.
7. Cliquez sur OK. Ouvrez une invite de commande (cmd) et tapez `gpupdate /force`.



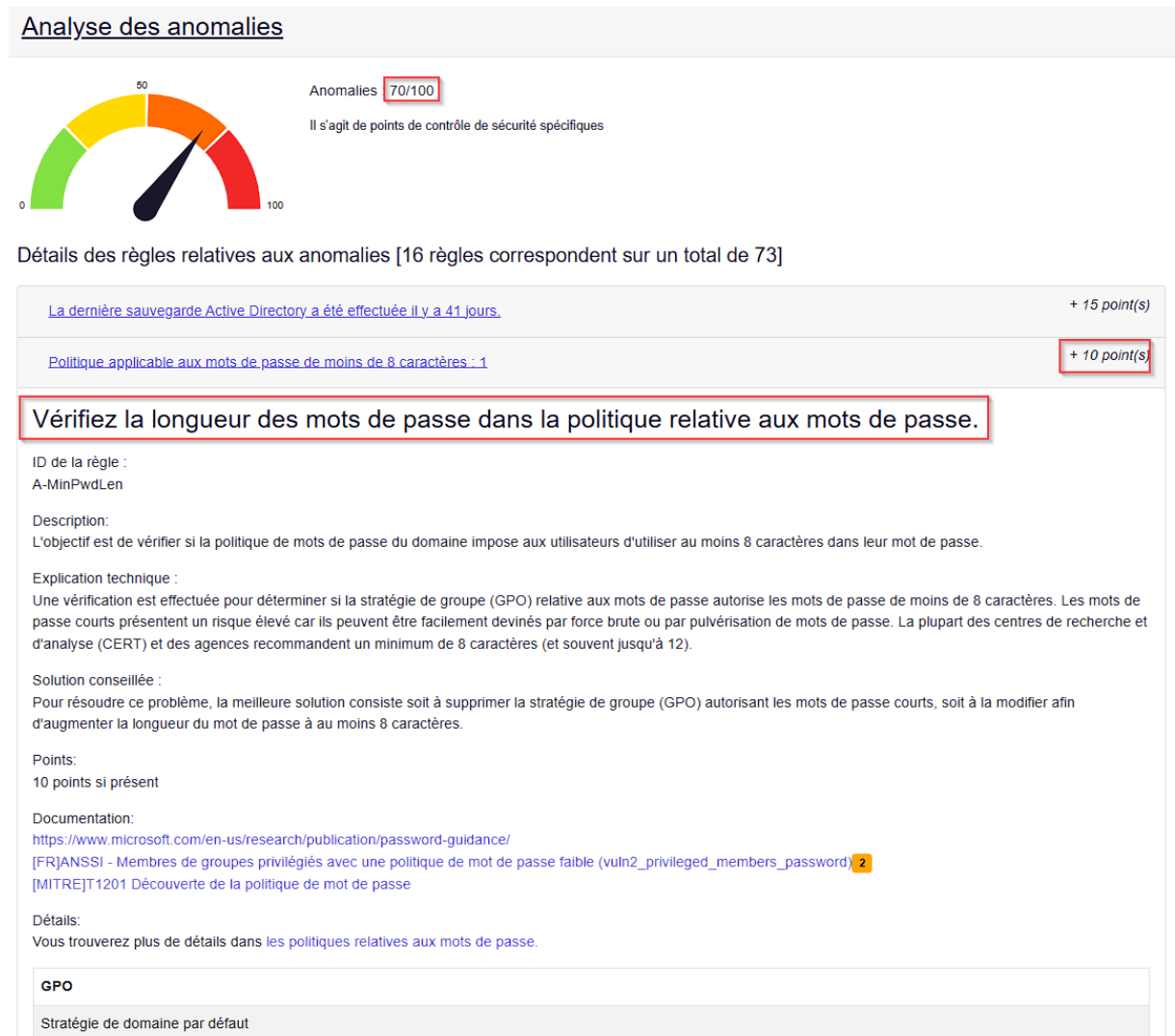
Re-générez un rapport PingCastle. Vous verrez que le score de cet indicateur a aussi baissé !



Nous sommes descendues à **16/100** et le curseur est désormais dans la **zone verte** !

MISSION 3 : RENFORCEMENT MOT DE PASSE (ANOMALIE)

La règle **A-MinPwdLen** (Longueur minimale du mot de passe) ne coûte que **10 points**, mais c'est la base absolue de la sécurité d'un système d'information.



1. Analyse de l'alerte PingCastle

La Règle (A-MinPwdLen) : Le domaine autorise les utilisateurs à créer des mots de passe trop courts (souvent 7 caractères par défaut).

Le Score (10 points) : C'est une faille d'hygiène de base. Les recommandations actuelles (ANSSI) exigent des mots de passe beaucoup plus longs.

Le Coupable : L'outil pointe précisément la `Stratégie de domaine par défaut` (Default Domain Policy). C'est la règle suprême qui s'applique à tous les utilisateurs.

2. La force brute

Il faut comprendre que la sécurité d'un mot de passe repose sur les mathématiques :

*"En cybersécurité, la complexité (majuscules, caractères spéciaux) est importante, mais **la longueur est reine** !*

*Avec les outils de piratage modernes comme **Hashcat** et une bonne carte graphique (GPU), un mot de passe de 7 caractères (même complexe) **se casse en quelques minutes**. Un mot de passe de 8 caractères prend quelques heures. Mais si vous imposez **12 caractères**, le temps de cassage passe à **plusieurs milliers d'années**. C'est pour cela que l'ANSSI recommande désormais 12 caractères minimum.*

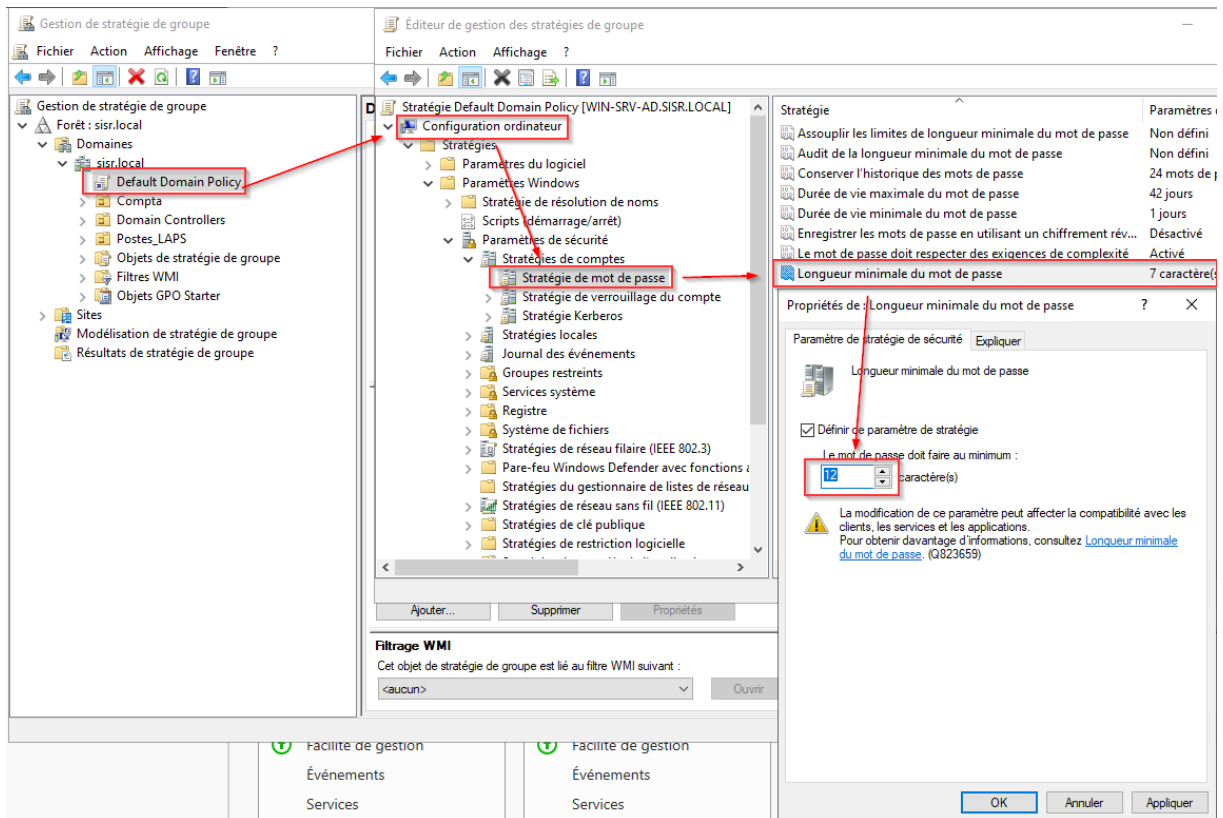
3. La Remédiation (Durcissement de la GPO)

Nous allons modifier la politique globale de l'entreprise. **Attention : PingCastle demande au moins 8, mais pour un niveau professionnel, on va configurer 12 caractères.**

Action requise sur le serveur Windows (DC01) :

1. Ouvrez la **Gestion de stratégie de groupe** (`gpmc.msc`).
2. Déroulez la forêt jusqu'à votre domaine (ex: `sirs.local`).
3. Faites un clic droit sur la **Stratégie de domaine par défaut** (Default Domain Policy) et cliquez sur **Modifier**.
4. Naviguez dans ce chemin :
*Configuration ordinateur > Stratégies > Paramètres Windows > Paramètres de sécurité > Stratégies de compte > **Stratégie de mot de passe**.*
5. Double-cliquez sur **Longueur minimale du mot de passe**.
6. Changez la valeur pour exiger **12 caractères** et validez.
7. Ouvrez une invite de commande (cmd) et tapez `gpupdate /force` pour appliquer la politique immédiatement.

Audit et sécu avec PingCastle



Re-générez un rapport PingCastle.

Anomalies analysis



Anomalies : 60 /100

It is about specific security control points

Anomalies rule details [15 rules matched on a total of 73]

Le curseur est bien descendu de **10 points** !

VII. BILAN ET MÉTHODOLOGIE D'EXAMEN (E6)

Validation Finale : Lancez une toute dernière fois PingCastle. Comparez le score initial et votre score final. Vous venez de réduire considérablement la surface d'attaque de votre entreprise !

Ce travail est le cœur du métier d'administrateur système moderne. Pour l'épreuve E6, voici comment présenter ce TP dans votre portfolio :

- **Ne dites pas :** "J'ai installé PingCastle et j'ai décoché des cases."
- **Dites :** "J'ai réalisé un audit de maturité de l'Active Directory avec PingCastle. J'ai identifié un risque de compromission lié à la présence de comptes de service dans le groupe Admin du Domaine, et j'ai appliqué le principe du moindre privilège pour y remédier, réduisant ainsi le score de risque global de 40%."